CTDMS

QA Test Report & Error Explainer

End-to-end test of v1.0 - live on the owner's laptop plus automated security and edge-case testing. Every issue with the steps that caused it, screenshots and the fix shipped in v1.1.

6	13	15	3	31
High	Medium	Low	Info / not a bug	Fixed in v1.1

Application	CTDMS - Central Transportation Expense & Dispatch Management System
Version tested	1.0.0 (laptop copy: C:\Users\Admin\Downloads\ctdms-v1.0claudeapp\ctdms)
Fixed version	1.1.0 (ctdms-v1.1.zip) - no database migration needed
Test date	26 September 2026
Environments	Windows laptop, Python 3.14, SQLite, Claude desktop browser (live) | Linux sandbox copy, SQLite + PostgreSQL 16, headless Chromium (automated)
Roles exercised	admin, operator.raipur, checker, viewer, cfa.raipur, accounts, management, operator.bilaspur, operator.durg
Prepared for	Samarth

1. Executive summary

> **Verdict:** the core dispatch workflow (verify → slip → print → complete), freight calculation, invoice-level data scope, CSRF, XSS escaping and the audit trail all work correctly. The weak spots were **records outside the invoice table** (transporter bills, import batches, rates) that ignored the user's CFA, **unsafe number and file handling** that could crash reports or tie up the server, and several **usability traps** in the dispatch screens. All High and Medium issues are fixed in v1.1 and covered by 43 new automated tests (71/71 pass on SQLite and PostgreSQL).

- **37 findings:** 6 High, 13 Medium, 15 Low, 3 Info. No Critical issue (no data loss, no login bypass, no injection into the database).
- **31 fixed**, 2 partly fixed / improved, 1 open recommendation, the rest by design or configuration.
- **Most important fixes:** CFA scope on bills, imports and rates (SEC-01/02/07); NaN/Infinity rows that crashed every report (SEC-04); unlimited uploads that blocked logins for 3 minutes (SEC-05); corrupt Excel files giving HTTP 500 (BUG-01, seen live on your laptop).
- **Before go-live:** install v1.1, set a strong CTDMS_SECRET_KEY, turn on HTTPS + CTDMS_SESSION_COOKIE_SECURE, start from an empty database (no demo users), and add per-IP login rate limiting in the reverse proxy (SEC-10).

2. What was tested and how

Track	What was done	Volume
Live, on your laptop	Real clicks in the Claude desktop browser against your running copy: login errors, full single dispatch, reprint, bulk dispatch, role checks (operator, viewer, checker, admin), approvals, void/cancel, import with a deliberately dirty file, corrupt-file upload, audit, settings, phone layout. Server log read back from the laptop.	~60 actions, ~50 screenshots
Automated probes	HTTP scripts for authentication, sessions, CSRF, open redirects, XSS, IDOR / cross-CFA access on web and API, privilege escalation, JWT tampering, upload abuse, bad parameters, concurrency (parallel clicks), formula injection.	121 checks, run on v1.0 and again on v1.1
Browser crawl	Every menu page for 7 roles in headless Chromium: HTTP status, JavaScript errors, load time, unlabeled form fields, page overflow.	136 page loads
Code review	Independent reviewer read every route, service and template for scope, permission, maker-checker, injection and money-handling issues and confirmed them against a test server.	11 issues, 10 confirmed on a test server
Regression tests	Existing suite plus one test per fixed issue, on SQLite and PostgreSQL 16.	71 / 71 pass

Changes made to your laptop's demo data during live testing

- Invoice 90012164 verified, slip DS/RPR/2627/00209 generated, printed, reprinted once and dispatched.
- MB/26/01372 and MB/26/01373 bulk-dispatched (slips 00210, 00211); MB/26/01371 completed.
- Override request #2 (CBO/RPR/04583, boxes 19 → 16) and rate #45 approved; slip of MB/26/01383 voided.
- Two import batches uploaded and cancelled (nothing imported). No production data exists on the laptop - everything is demo data and can be reset (see the user guide).

3. What works well (passed)

Area	Result
Login / logout	Wrong password message, logout, server-side session revoked (old cookie rejected after logout), CSRF token required on every form and API write
Dispatch workflow	Verify (18 x ₹5.00 = ₹90.00), vehicle/LR normalised, Complete blocked until the slip is generated AND printed, fields lock after slip, A5 slip correct, completion recorded
Reprint / void / cancel	Reprint needs a reason (browser + server), prints 'REPRINT #1 (DUPLICATE)'; void returns to Verified; cancelling a completed dispatch limited to admin
Bulk dispatch	One truck for 2 invoices, validation of required fields, 2 slips issued, bulk print, 3 completed
Concurrency	5 parallel 'Generate slip' clicks -> one dispatch number; 4 parallel 'Complete' -> completed once
Data scope (invoices)	Raipur operator sees only Raipur (234 invoices); 64 other-CFA invoices 403 in web, 404 in API; all 6 dispatch actions blocked cross-CFA
Roles	Viewer: reports only, export blocked (UI and direct URL); operator blocked from users, settings, rates; checker approvals with maker-checker
Import validation	Bad date, negative boxes, unknown company/customer, text in amounts, future date, duplicates (in file and existing), row correction and re-validation
Upload safety	.html / .exe rejected, empty file rejected, path-trick file names stored safely
XSS / redirects	HTML in names and search boxes shown as text; 5 open-redirect variants blocked
API	No token -> 401, garbage / alg=none JWT -> 401, page size capped, negative values rejected
Performance	136 page loads over 7 roles: 0 JavaScript errors, every page < 0.9 s
Audit trail	Every action in this test (verify, slip, print, reprint, void, approvals, imports, logins) recorded with user, time and IP

4. Findings at a glance

Severity: **High** = security / data-integrity risk or a crash in a core flow; **Medium** = wrong behaviour or a trap users will hit; **Low** = polish, hardening, accessibility; **Info** = by design, configuration or not an app bug.

ID	Severity	Area	Issue	Status
SEC-01	HIGH	Reconciliation / data scope	Transporter bills ignore the user's CFA - a Raipur manager can see and approve Bilaspur bills	FIXED
SEC-02	HIGH	Invoice import / data scope	Import batches of other CFAs can be opened, edited, committed or cancelled	FIXED
SEC-03	HIGH	Invoice import / ERP mapping	Any importer can re-point a global ERP customer code to a different customer	FIXED
SEC-04	HIGH	Numbers / reports	'Infinity' / 'NaN' accepted as numbers - one bad row crashes the dashboard and all reports	FIXED
SEC-05	HIGH	Uploads / availability	No size or row limit on rate and transporter-bill uploads (server can be tied up)	FIXED
BUG-01	HIGH	Invoice / rate / bill import	A damaged or fake Excel file crashes the upload with '500 Something went wrong'	FIXED
SEC-06	MEDIUM	Exports	Spreadsheet formula injection in Excel / CSV exports	FIXED
SEC-07	MEDIUM	Freight rates / data scope	Freight rates only checked the company, not the CFA	FIXED
SEC-08	MEDIUM	Login / passwords	'Must change password' was not enforced	FIXED
REC-01	MEDIUM	Reconciliation	Bill total counted invoices that do not belong on the bill (double-payment risk)	FIXED
REC-02	MEDIUM	Reconciliation / maker-checker	A second accounts user could edit bill amounts and then approve the same bill	FIXED
BUG-02	MEDIUM	Error handling	HTTP 500 on unexpected input in the address bar or forms	FIXED
BUG-03	MEDIUM	REST API	API returned 500 instead of 422 when a body is sent in the wrong format	FIXED
UX-01	MEDIUM	Dispatch entry	False warnings 'Dispatch date missing / Dispatch time missing'	FIXED
UX-02	MEDIUM	Dispatch / approvals	No 'Are you sure?' before irreversible actions	FIXED
UX-03	MEDIUM	Bulk dispatch	Bulk result page: green 'Complete' button before printing; failure loses the page	FIXED
UX-04	MEDIUM	Reports / permissions	Read-only users see invoice links that all end in '403 Access denied'	FIXED
UX-05	MEDIUM	Invoice import	Implausible values accepted as 'Valid' (99,999 boxes on a ₹50,000 invoice)	FIXED
UX-06	MEDIUM	Dispatch entry	Vehicle number never checked; LR re-use silent	FIXED
SEC-09	LOW	Audit trail	IP address in the audit log could be faked with an X-Forwarded-For header	FIXED
SEC-10	LOW	Login	Lockout without warning; anyone can lock any account	PARTLY FIXED
SEC-11	LOW	Security headers / API	No Content-Security-Policy; Swagger /api/docs public	FIXED
SEC-12	LOW	Passwords	Weak passwords accepted (e.g. 'password1', 'Demo@123')	FIXED
SEC-13	LOW	Masters / data scope	Other CFAs visible in master detail pages and the masters API	FIXED

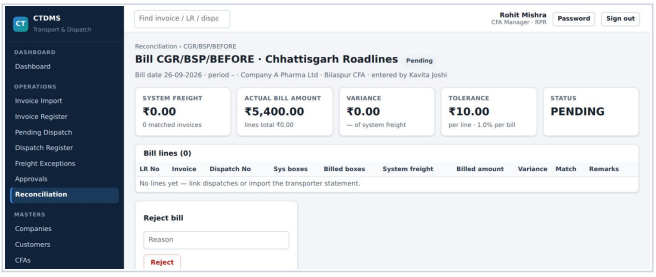
ID	Severity	Area	Issue	Status
SEC-14	LOW	Deployment defaults	Demo logins shown by default; default secret key only produced a warning	FIXED
UX-07	LOW	Dispatch entry (read-only roles)	Checker sees 'No active slip' although a slip exists; misleading lock badge	FIXED
UX-08	LOW	Freight rates	Closing a future rate said 'closed with effect to ...' although it was deactivated	FIXED
UX-09	LOW	Mobile / narrow screens	Phone layout: filters fill the screen, action bar covers the list	IMPROVED
UX-10	LOW	Approvals	Approve / Reject buttons pushed off-screen on narrower windows	FIXED
UX-11	LOW	Pending dispatch queue	Old 'rate missing' invoices at the top of the operator's queue	FIXED
UX-12	LOW	Login page	Demo login helper only reacted when clicking the username text	FIXED
UX-13	LOW	Reprint	Reprint reason: browser demanded 5 characters, server 3	FIXED
A11Y-01	LOW	Accessibility	Form labels not connected to their fields	FIXED
REC-03	LOW	Reconciliation	An approved (not yet paid) bill can still be rejected by another approver	OPEN
INFO-01	INFO	Slip printing	Print event is recorded when the print page opens, even if the printer dialog is cancelled	BY DESIGN
INFO-02	INFO	Deployment	Session cookie 'Secure' flag must be switched on with HTTPS	CONFIG
INFO-03	INFO	Login	Login with Enter did not move to the next page in the desktop app's browser pane	NOT A BUG

5. Screenshot explainer - every issue, how it happened, and the fix

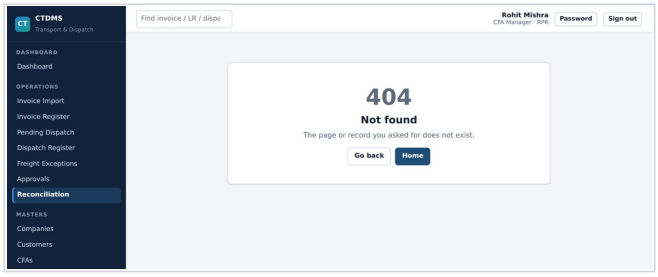
Each card shows the exact steps that trigger the problem, what should happen, what actually happened, the fix in v1.1 and - where useful - screenshots: **live** ones taken on your laptop during the test, and **v1.0 / v1.1** pairs reproduced side by side on a copy of the app.

SEC-01	HIGH	**Transporter bills ignore the user's CFA - a Raipur manager can see and approve Bilaspur bills**	FIXED

Area	Reconciliation / data scope
Steps that caused it	1. Log in as accounts and create a transporter bill for Company A / Bilaspur CFA. 2. Log out, log in as cfa.raipur (CFA Manager, Raipur only). 3. Open Reconciliation, or type /recon/<bill id> in the address bar. 4. Enter any remark and click Approve (or Reject).
Expected	Bills of other CFAs are invisible; approve/reject is impossible.
Actual	The full bill with its invoice lines is shown and the Raipur manager can approve or reject it (confirmed: a Bilaspur bill was approved in the test copy). The list, the Approvals page and the bill reports were also unscoped.
Fix / recommendation	Bills now use a strict company + CFA scope in the list, detail page, every action, the Approvals queue and the bill reports. Out-of-scope bills return 404. New bills must be inside the creator's scope.



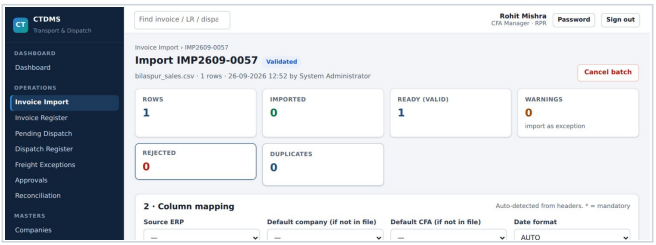
v1.0 - Raipur manager viewing a Bilaspur bill (Reject button available)



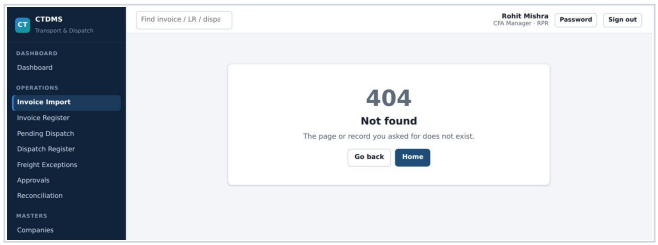
v1.1 - same URL now returns 404

SEC-02	HIGH	**Import batches of other CFAs can be opened, edited, committed or cancelled**	FIXED

Area	Invoice import / data scope
Steps that caused it	1. Admin uploads an invoice file with Default CFA = Bilaspur. 2. Log in as cfa.raipur and open /imports/<batch id> (it is also listed on the Import page). 3. Edit a row (e.g. sales value) or click Cancel batch.
Expected	Only batches uploaded by the user or tagged with their own CFA are accessible.
Actual	The Raipur user could open the Bilaspur batch, change row values and cancel it.
Fix / recommendation	Batch access limited to the uploader or users whose scope covers the batch CFA (all-scope users see everything). The import log list is filtered the same way.



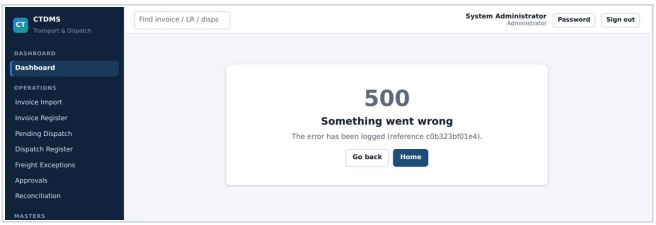
v1.0 - Raipur manager inside a Bilaspur import batch



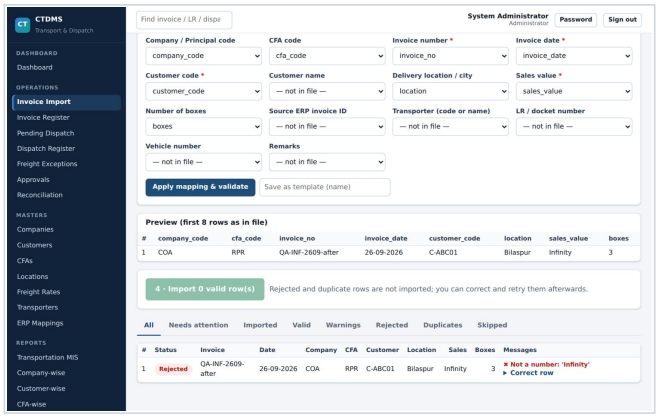
v1.1 - 404

SEC-03	**HIGH**	**Any importer can re-point a global ERP customer code to a different customer**	**FIXED**
Area	Invoice import / ERP mapping		
Steps that caused it	1. As cfa.raipur (no Masters-edit right) open an import batch with a missing customer. 2. In 'Map ERP code' enter an ERP code that is already mapped (e.g. 100245) and pick another customer. 3. Click Map ERP code.		
Expected	Changing an existing mapping needs Masters edit rights.		
Actual	The global mapping was overwritten (audit: ERP_MAPPING_CHANGED). All future invoices with that code would land on the wrong customer, rate and location.		
Fix / recommendation	New mappings are still allowed for importers; changing an existing mapping now needs master.edit and shows a clear message.		

SEC-04	**HIGH**	**'Infinity' / 'NaN' accepted as numbers - one bad row crashes the dashboard and all reports**	**FIXED**
Area	Numbers / reports		
Steps that caused it	1. Invoice Import > upload a CSV whose Sales value is 'Infinity' (or 'NaN', '1e400'). 2. The row shows as Valid; click 'Import valid rows'. 3. Open Dashboard, MIS, Invoice Register or any report.		
Expected	Row rejected: not a number.		
Actual	Dashboard, MIS, reports and the dashboard API return '500 Something went wrong' for every user in scope until the invoice is removed from the database. The same values also crashed overrides, rate entry and bill amounts.		
Fix / recommendation	The number parser now rejects NaN/Infinity and values >= 1,000,000,000,000 everywhere (imports, API, forms, overrides, rates, bills).		



v1.0 - dashboard after importing one 'Infinity' row



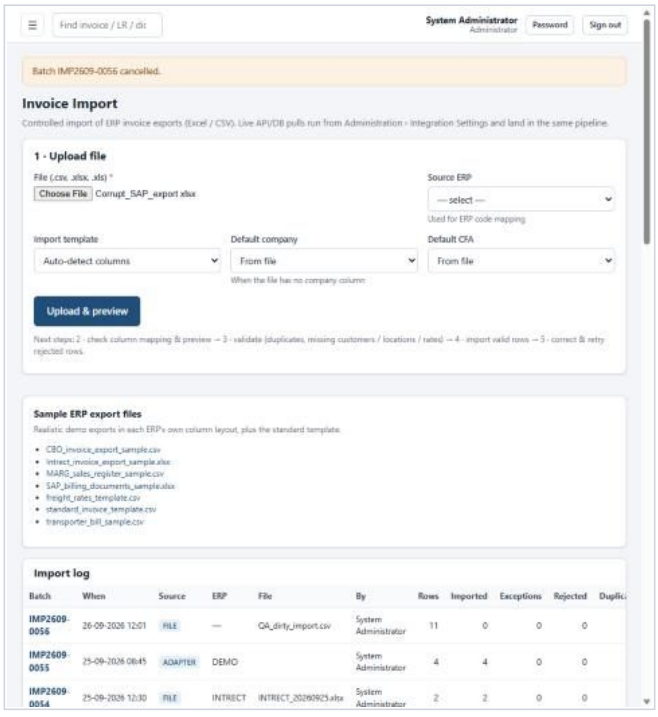
v1.1 - row rejected with 'Not a number: Infinity'

SEC-05	HIGH	No size or row limit on rate and transporter-bill uploads (server can be tied up)	FIXED

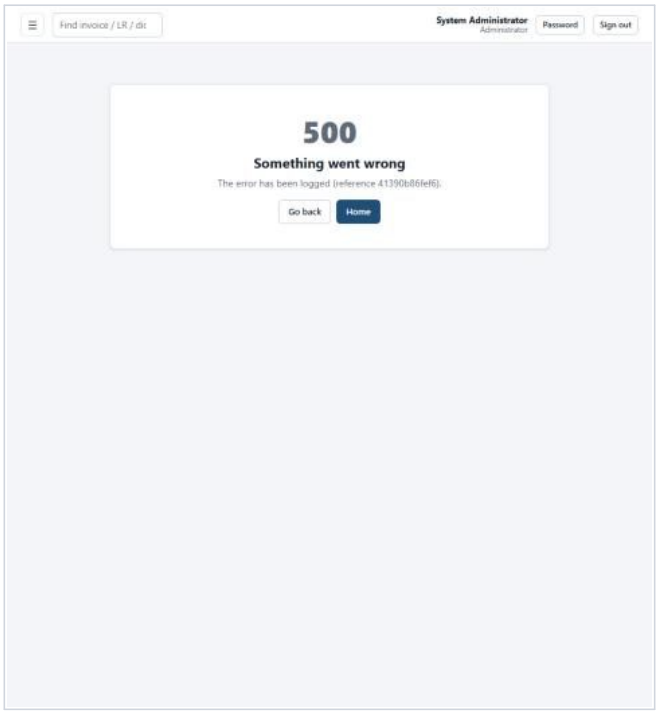
Area	Uploads / availability
Steps that caused it	1. Freight Rates > Import, choose a 28 MB CSV (7 million short rows). 2. While it runs, let another user try to sign in.
Expected	File rejected immediately: 'File too large (max 20 MB)'.
Actual	The request ran for 184 seconds using 2.2 GB RAM; concurrent logins failed with HTTP 500 ('database is locked'). Only invoice import had a limit, and even there the whole file was read into memory first.
Fix / recommendation	All three importers read at most 20 MB (configurable CTDMS_MAX_UPLOAD_MB) and at most 100,000 rows; larger files are refused in under a second.

BUG-01	HIGH	A damaged or fake Excel file crashes the upload with '500 Something went wrong'	FIXED

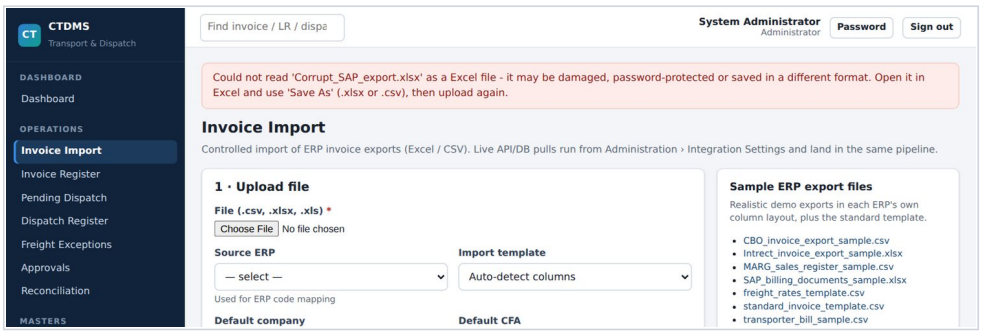
Area	Invoice / rate / bill import
Steps that caused it	1. Invoice Import > Choose File: an .xlsx that is not a real Excel workbook (renamed CSV, broken download, password-protected file). 2. Click 'Upload & preview'.
Expected	A clear message telling the user the file cannot be read and what to do.
Actual	HTTP 500 error page (server log: BadZipFile). Reproduced live on the laptop at 12:02; the same happens on Freight Rates > Import and on transporter-bill import, also for .xls files.
Fix / recommendation	File reading is wrapped: the user now sees "Could not read '<file>' as a Excel file - it may be damaged, password-protected ... use Save As (.xlsx or .csv)".



Live on your laptop - file selected



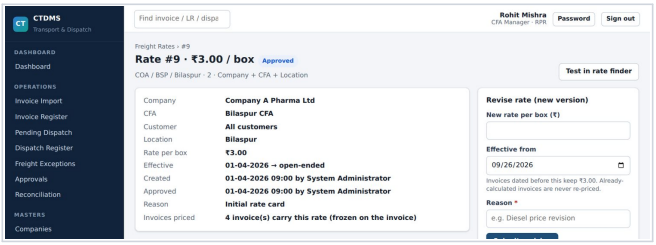
Live on your laptop - result: HTTP 500



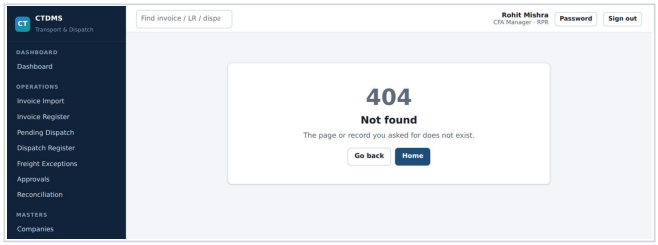
v1.1 - friendly message

SEC-06	MEDIUM	Spreadsheet formula injection in Excel / CSV exports	FIXED
Area	Exports		
Steps that caused it	1. A customer name arrives from an ERP file (or is typed in Masters) as =HYPERLINK("http://evil.example","Click"). 2. Export any report containing it to Excel or CSV and open the file.		
Expected	The text is shown as text.		
Actual	Excel writes it as a live formula (clickable link / could run other formulas).		
Fix / recommendation	Every exported text cell starting with = + - @ is prefixed with an apostrophe (report Excel/CSV and masters CSV). Numbers are unaffected.		

SEC-07	MEDIUM	Freight rates only checked the company, not the CFA	FIXED
Area	Freight rates / data scope		
Steps that caused it	1. Log in as cfa.raipur. 2. Open /rates/9 (a Bilaspur rate). 3. Use 'Revise rate' or create a new Bilaspur rate.		
Expected	Raipur user can view company-wide rates but cannot change Bilaspur rates.		
Actual	Bilaspur rate details visible and revisable; new Bilaspur rates could be created.		
Fix / recommendation	View = company in scope and CFA in scope or company-wide. Create / revise / approve / close = fully inside the user's scope. Rate finder and rate reports scoped too.		



v1.0 - Raipur manager on a Bilaspur rate with 'Revise rate' form



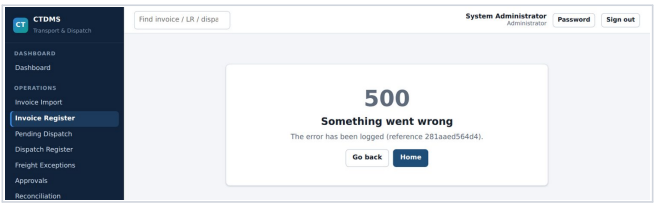
v1.1 - 404

SEC-08	**MEDIUM**	**'Must change password' was not enforced**	**FIXED**
Area	Login / passwords		
Steps that caused it	1. Admin creates or resets a user (flag: must change password). 2. User logs in: redirected once to Change password. 3. User simply clicks Dashboard / Reports or requests an API token.		
Expected	Nothing else works until the password is changed.		
Actual	All pages worked and the API issued a token.		
Fix / recommendation	Every page (except change password / logout) redirects to Change password while the flag is set; the API refuses tokens with HTTP 403.		

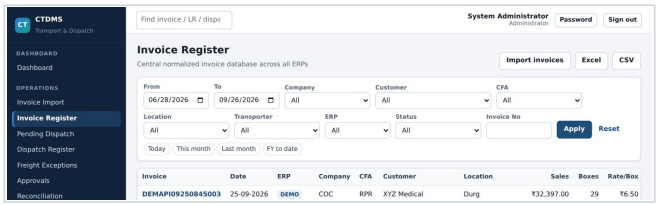
REC-01	**MEDIUM**	**Bill total counted invoices that do not belong on the bill (double-payment risk)**	**FIXED**
Area	Reconciliation		
Steps that caused it	1. Create a bill for transporter CGR. 2. Add one CGR dispatched invoice and one invoice that is not dispatched (or dispatched by another transporter). 3. Look at System freight / Variance, then approve.		
Expected	Only valid lines count; the bill cannot be approved while it contains problem lines.		
Actual	System freight included the invalid lines, so variance showed 0 and the bill could be approved with a short remark - the other transporter could later bill the same dispatch again.		
Fix / recommendation	Only MATCHED / VARIANCE / UNBILLED lines count towards system freight. Approval is blocked while NOT FOUND, NOT DISPATCHED, DUPLICATE or OTHER TRANSPORTER lines exist.		

REC-02	**MEDIUM**	**A second accounts user could edit bill amounts and then approve the same bill**	**FIXED**
Area	Reconciliation / maker-checker		
Steps that caused it	1. User A enters the bill. 2. User B (has edit + approve) changes line amounts or the bill amount. 3. User B approves.		
Expected	Whoever changed the amounts cannot approve.		
Actual	Approved - maker-checker only compared with the bill creator.		
Fix / recommendation	Approval blocked for any user who linked, imported, edited, allocated or deleted lines on that bill (from the audit trail). Amount edits on approved/paid bills are also blocked now.		

BUG-02	**MEDIUM**	**HTTP 500 on unexpected input in the address bar or forms**	**FIXED**
Area	Error handling		
Steps that caused it	1. Open /invoices?page=abc (same for Pending Dispatch, Dispatch Register, Masters lists). 2. Or open /invoices/99999999999999999999, a report with company_id=99999999999999999999, ERP mappings with entity=FOO, or post transporter_id=abc / role_id=abc.		
Expected	The page ignores the bad value or shows 404 / a validation message.		
Actual	'500 Something went wrong'.		
Fix / recommendation	Safe number parsing for all ids and page numbers; ids longer than 18 digits no longer match a route (404).		



v1.0 - /invoices?page=abc



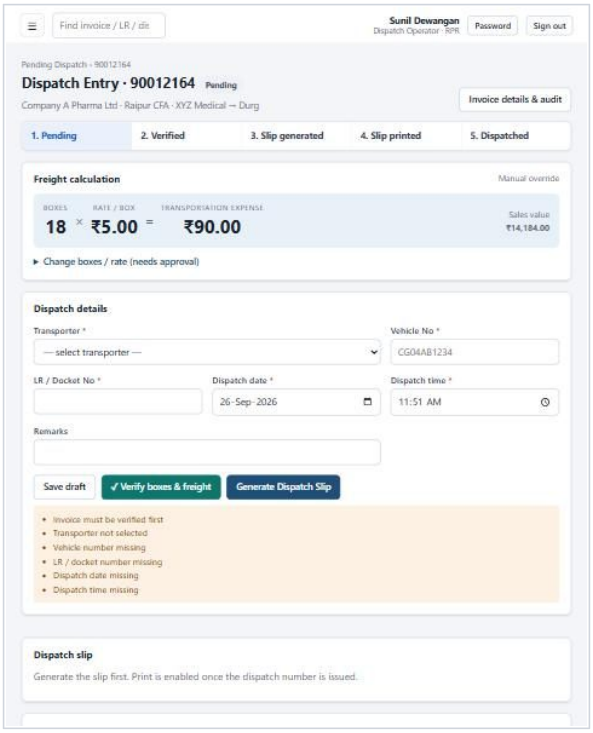
v1.1 - list shown normally

BUG-03	**MEDIUM**	**API returned 500 instead of 422 when a body is sent in the wrong format**	**FIXED**

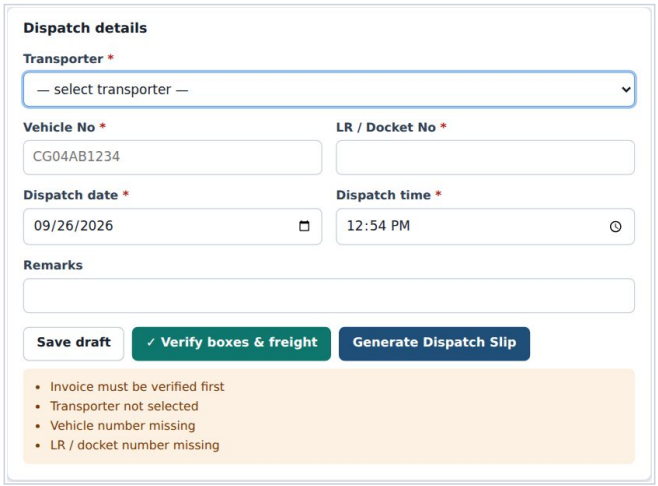
Area	REST API
Steps that caused it	1. POST /api/v1/auth/token with form data instead of JSON (a common integration mistake).
Expected	HTTP 422 with the validation errors.
Actual	HTTP 500 - the error handler could not serialise the raw bytes in the error.
Fix / recommendation	Validation errors are JSON-encoded safely.

UX-01	**MEDIUM**	**False warnings 'Dispatch date missing / Dispatch time missing'**	**FIXED**

Area	Dispatch entry
Steps that caused it	1. Operator opens any new pending invoice.
Expected	Only real blockers are listed.
Actual	The form is pre-filled with today's date and time (and these are saved on generate), yet the warning list says both are missing. Seen live on invoice 90012164.
Fix / recommendation	Pre-filled date/time are no longer reported as missing.



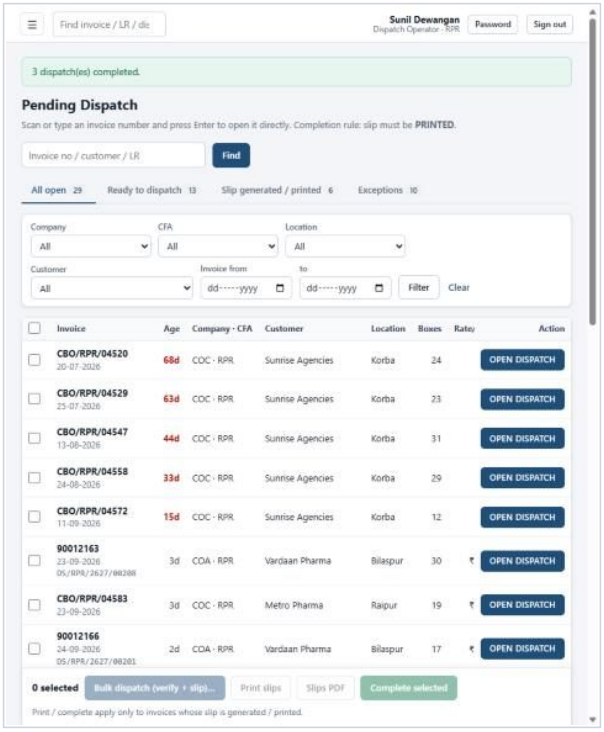
Live on your laptop (invoice 90012164) - date and time are filled, yet listed as missing



v1.1 - only real blockers

UX-02	**MEDIUM**	**No 'Are you sure?' before irreversible actions**	**FIXED**

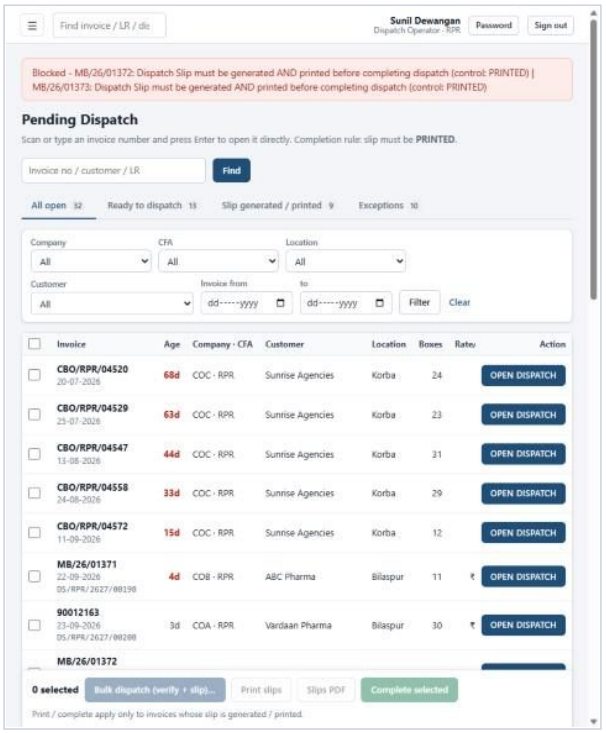
Area	Dispatch / approvals
Steps that caused it	1. Pending Dispatch > Slip generated tab > tick 3 invoices > Complete selected. 2. (Same for Complete Dispatch, Void slip, Cancel dispatch, Reject, Mark paid, Merge customer, Cancel import batch.)
Expected	A confirmation step.
Actual	One click completed 3 dispatches immediately (live test). A misclick cannot be undone without an administrator.
Fix / recommendation	Confirmation dialogs with the invoice / bill number on all irreversible buttons.



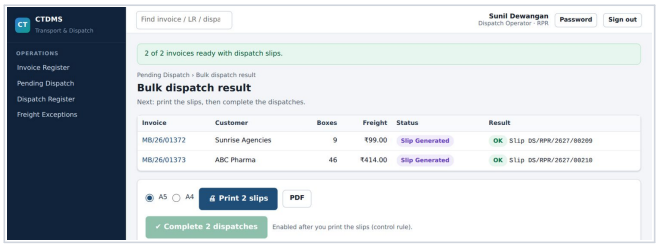
Live - three dispatches completed by one click

UX-03	**MEDIUM**	**Bulk result page: green 'Complete' button before printing; failure loses the page**	**FIXED**

Area	Bulk dispatch
Steps that caused it	1. Bulk dispatch 2 invoices (verify + slip). 2. On the result page click 'Complete 2 dispatches' before printing.
Expected	Complete is available only after printing (control rule PRINTED); errors keep the user where the work is.
Actual	Button looked ready; it failed with a long error repeated for each invoice and sent the user back to the All-open list, so the bulk page was lost.
Fix / recommendation	Complete is disabled until the slips are printed from that page; errors are grouped into one line and the user lands on the 'Slip generated / printed' tab.



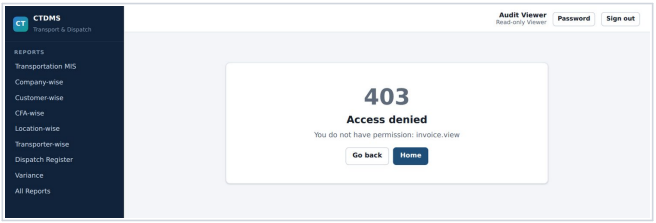
Live - error after clicking Complete too early



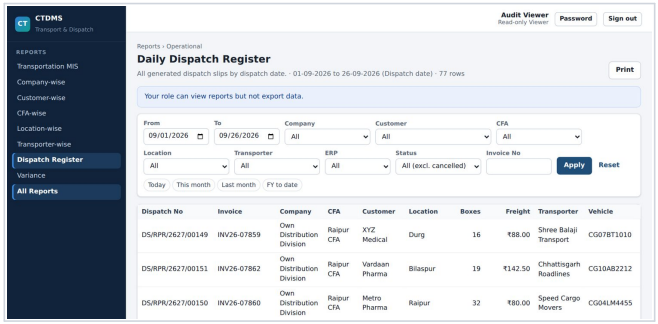
v1.1 - Complete disabled until printing

UX-04 MEDIUM Read-only users see invoice links that all end in '403 Access denied' FIXED

Area	Reports / permissions
Steps that caused it	1. Log in as viewer. 2. Reports > Dispatch Register (or MIS drill-down to invoice level). 3. Click any invoice number.
Expected	Plain text for users who cannot open invoices.
Actual	80 links on the Dispatch Register alone, each opening 403.
Fix / recommendation	Links shown only to roles with invoice / reconciliation access (reports and MIS).



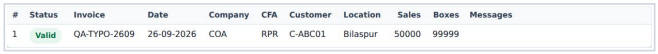
v1.0 - viewer clicked an invoice link



v1.1 - register without dead links

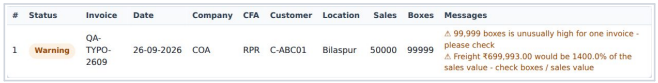
UX-05	MEDIUM	Implausible values accepted as 'Valid' (99,999 boxes on a ₹50,000 invoice)	FIXED

Area	Invoice import
Steps that caused it	1. Import a row with Boxes = 99999 and Sales value = 50000.
Expected	Row flagged for a second look.
Actual	Marked Valid; would create ₹7 lakh of freight (1,400% of sales).
Fix / recommendation	Warning when boxes > 2,000 or freight > 10% of sales value (row still importable after review).



#	Status	Invoice	Date	Company	CFA	Customer	Location	Sales	Boxes	Messages
1	Valid	QA-TYPO-2609	26-09-2026	COA	RPR	C-ABC01	Bilaspur	50000	99999	

v1.0



#	Status	Invoice	Date	Company	CFA	Customer	Location	Sales	Boxes	Messages
1	Warning	QA-TYPO-2609	26-09-2026	COA	RPR	C-ABC01	Bilaspur	50000	99999	⚠ 99,999 boxes is unusually high for one invoice - please check ⚠ Freight ₹699,993.00 would be 1400.0% of the sales value - check boxes / sales value

v1.1

UX-06	MEDIUM	Vehicle number never checked; LR re-use silent	FIXED

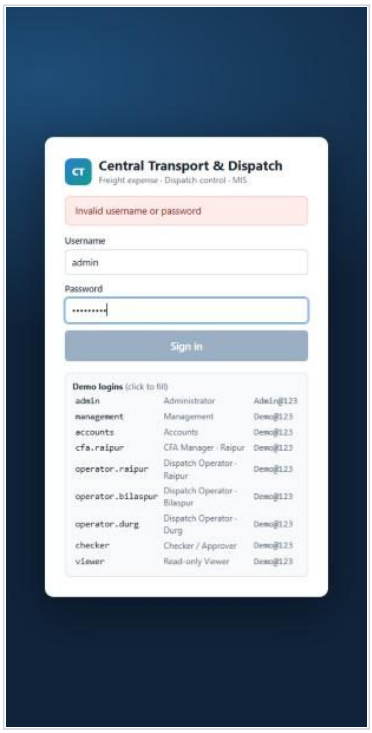
Area	Dispatch entry
Steps that caused it	1. Enter vehicle 'HELLO' and save / verify / generate.
Expected	A warning for numbers that do not look like registrations.
Actual	Accepted and printed on the slip. (A format checker existed in the code but was never used.)
Fix / recommendation	Non-blocking warnings for odd vehicle numbers (CG04AB1234, 22BH1234AA, SELF/HAND accepted) and for an LR already used by the same transporter.

SEC-09	LOW	IP address in the audit log could be faked with an X-Forwarded-For header	FIXED

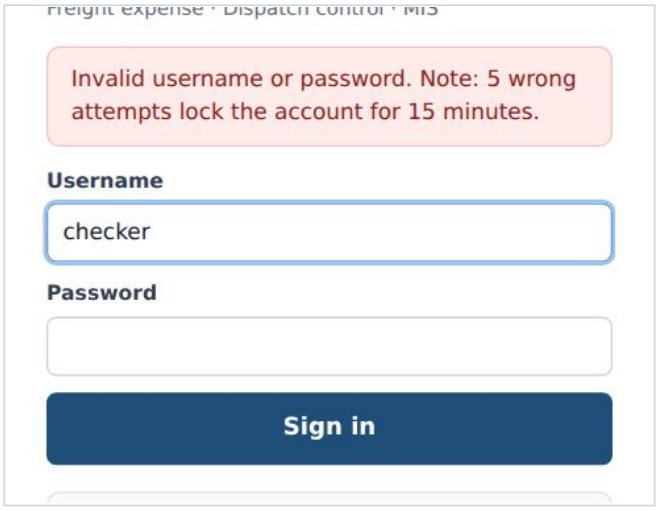
Area	Audit trail
Steps that caused it	1. Send any request with header X-Forwarded-For: 203.0.113.66. 2. Open Reports > Audit.
Expected	Real client IP.
Actual	The fake IP was recorded.
Fix / recommendation	Only the web server's trusted-proxy setting (FORWARDED_ALLOW_IPS, default 127.0.0.1) decides the client IP.

SEC-10	LOW	Lockout without warning; anyone can lock any account	PARTLY FIXED

Area	Login
Steps that caused it	1. Enter a wrong password 5 times (this happened on the laptop at 05:26 today).
Expected	Users are told the rule before they are locked out.
Actual	Only 'Invalid username or password' until the account locked for 15 minutes. Any person can lock the admin account the same way.
Fix / recommendation	Message now states the rule on every failure (same text for unknown users, so usernames cannot be probed). Recommended next step (open): per-IP rate limiting in the reverse proxy.



Live on your laptop



v1.1

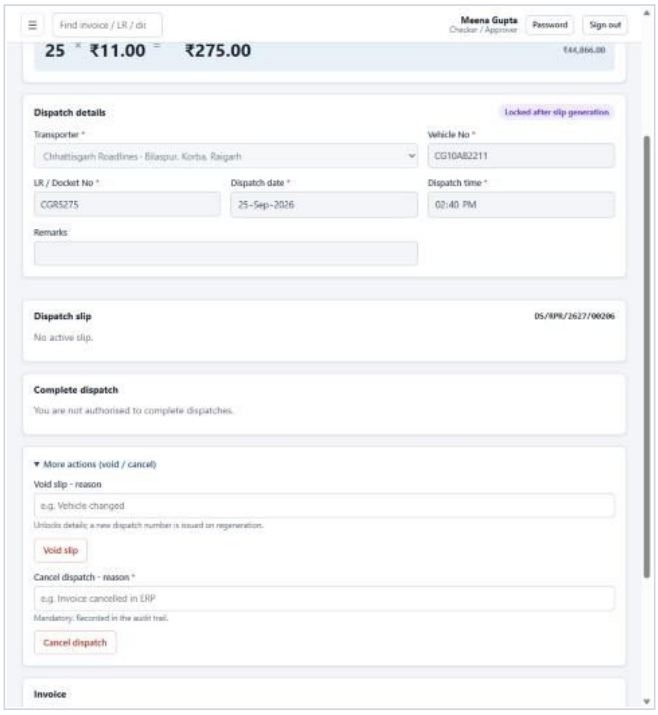
SEC-11	LOW	No Content-Security-Policy; Swagger /api/docs public	FIXED
Area	Security headers / API		
Steps that caused it	1. Inspect response headers; open /api/docs without logging in.		
Expected	CSP present; API documentation not public in production.		
Actual	No CSP; full API schema public.		
Fix / recommendation	CSP header added; /api/docs and /api/openapi.json are off in production unless CTDMS_API_DOCS_PUBLIC=true.		

SEC-12	LOW	Weak passwords accepted (e.g. 'password1', 'Demo@123')	FIXED
Area	Passwords		
Steps that caused it	1. Account > Password > new password 'password1'.		
Expected	Rejected.		
Actual	Accepted.		
Fix / recommendation	Common/demo passwords and passwords containing the username are refused.		

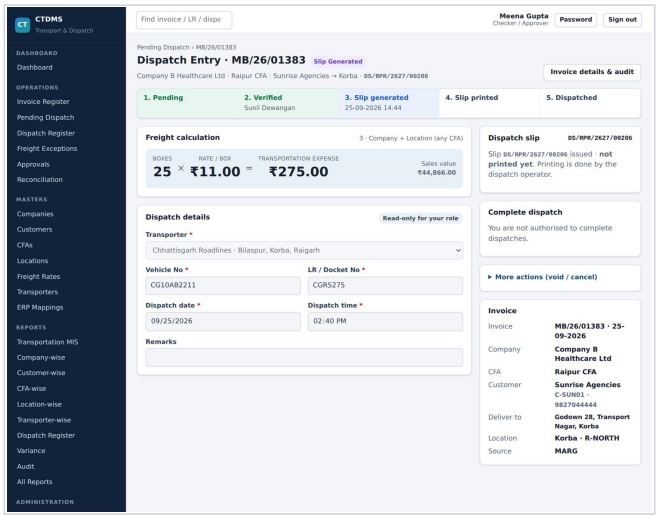
SEC-13	LOW	Other CFAs visible in master detail pages and the masters API	FIXED
Area	Masters / data scope		
Steps that caused it	1. As cfa.raipur open /masters/cfas/2, or GET /api/v1/masters/cfas.		
Expected	Only assigned CFAs / companies.		
Actual	Bilaspur CFA details and all CFAs listed.		
Fix / recommendation	Company / CFA master pages and API list filtered by scope. (Opening another CFA's invoice still shows a clear 403 message on purpose, so a scanner operator knows why.)		

SEC-14	LOW	Demo logins shown by default; default secret key only produced a warning	FIXED
Area	Deployment defaults		
Steps that caused it	1. Deploy without a .env file / with the sample secret.		
Expected	Safe defaults in production.		
Actual	Login page listed demo usernames and passwords; sessions signed with a public default key.		
Fix / recommendation	Demo logins are off by default in production; the app refuses to start in production with the default or a short secret key (message explains how to generate one).		

UX-07	LOW	Checker sees 'No active slip' although a slip exists; misleading lock badge	FIXED
Area	Dispatch entry (read-only roles)		
Steps that caused it	1. Log in as checker and open an invoice with a generated slip. 2. Void the slip.		
Expected	Slip number and print state shown; badge explains the role is read-only.		
Actual	'No active slip.'; after voiding, 'Locked after slip generation' still shown.		
Fix / recommendation	Shows 'Slip DS/... issued - not printed yet / printed N x' and 'Read-only for your role'.		



Live on your laptop



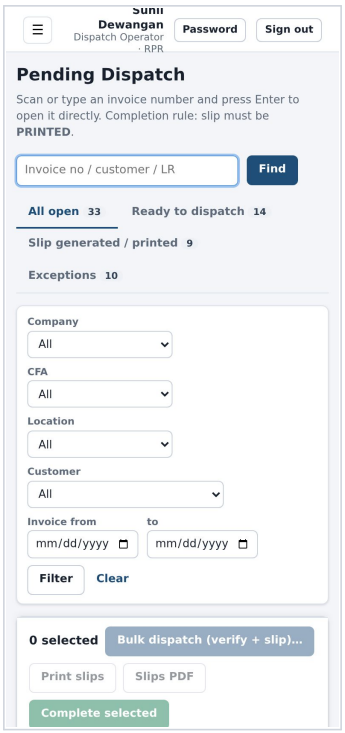
v1.1

UX-08	**LOW**	**Closing a future rate said 'closed with effect to ...' although it was deactivated**	**FIXED**

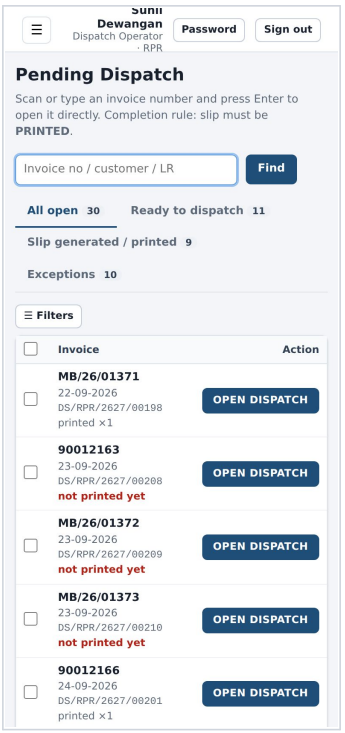
Area	Freight rates
Steps that caused it	1. Approve a rate effective 01-11-2026. 2. Close it with date 01-09-2026.
Expected	Message says it was deactivated (never started).
Actual	Success message with the earlier date (data itself was correct: INACTIVE).
Fix / recommendation	Clear message for this case.

UX-09	**LOW**	**Phone layout: filters fill the screen, action bar covers the list**	**IMPROVED**

Area	Mobile / narrow screens
Steps that caused it	1. Open Pending Dispatch on a phone (390 px wide).
Expected	List visible first; filters on demand.
Actual	Four filter boxes plus a permanent bottom bar; only invoice number + button visible per row.
Fix / recommendation	Filters collapse behind a 'Filters' button, action bar appears only when something is selected, slip/print state shown under the invoice number. The table still scrolls sideways on phones (open).



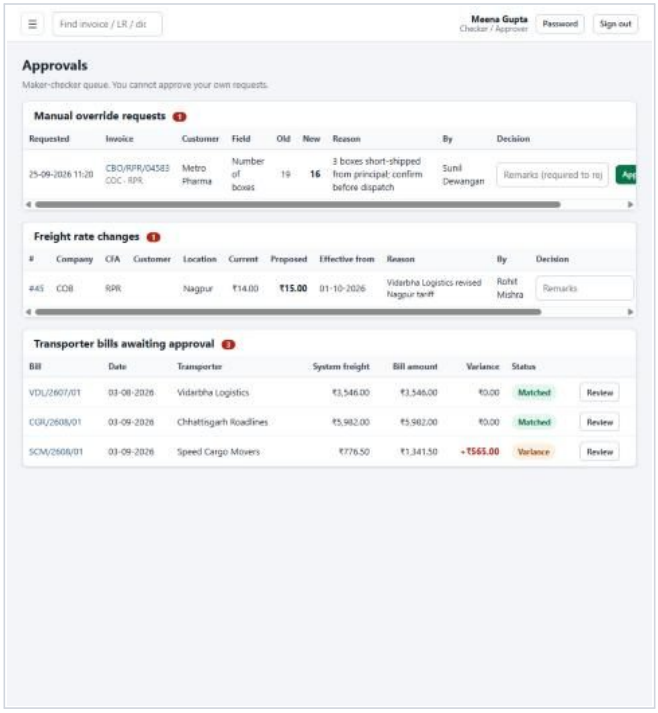
v1.0 (phone)



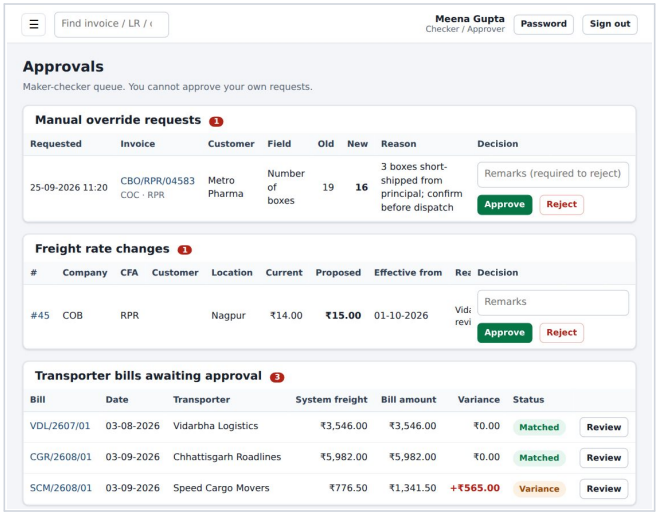
v1.1 (phone)

UX-10	**LOW**	**Approve / Reject buttons pushed off-screen on narrower windows**	**FIXED**

Area	Approvals
Steps that caused it	1. Open Approvals in a window narrower than ~1100 px.
Expected	Decision buttons always visible.
Actual	Buttons outside the visible table area.
Fix / recommendation	Decision column kept visible (sticky) and wraps.



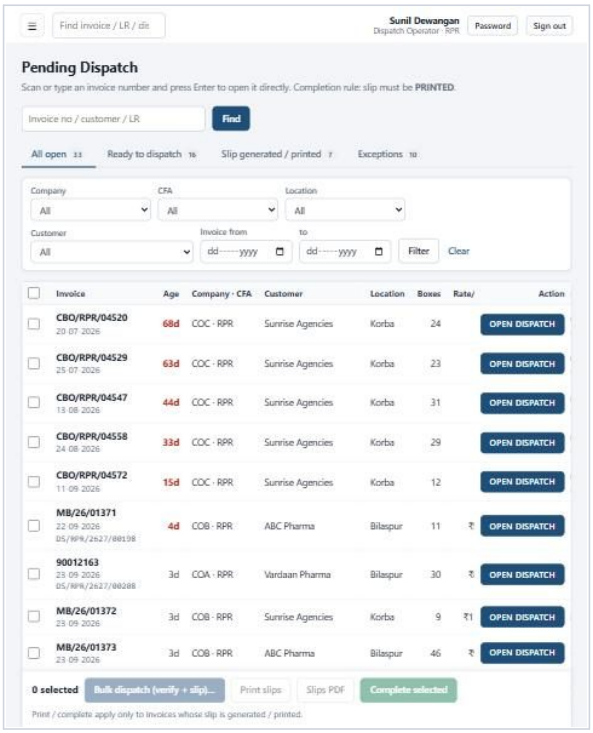
Live on your laptop



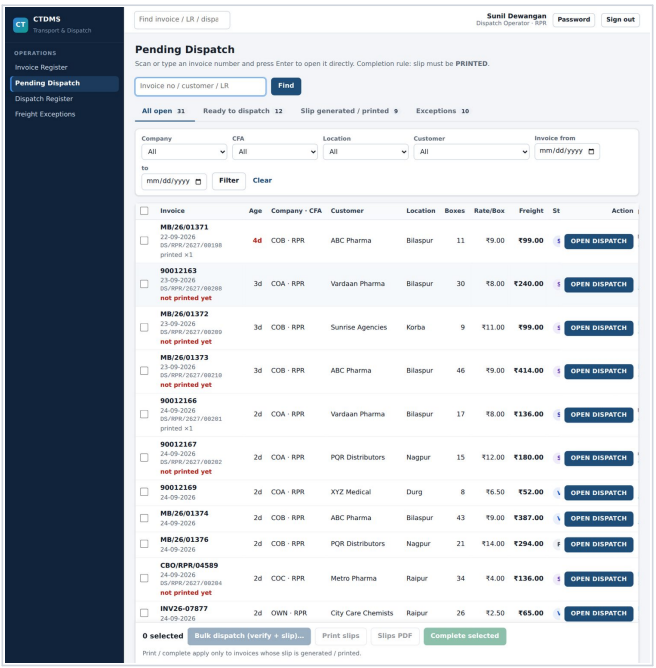
v1.1

UX-11	**LOW**	**Old 'rate missing' invoices at the top of the operator's queue**	**FIXED**

Area	Pending dispatch queue
Steps that caused it	1. Operator opens Pending Dispatch (All open).
Expected	Work the operator can do now comes first.
Actual	5 blocked CBO invoices (68 days old, no rate) filled the top rows.
Fix / recommendation	Blocked invoices (rate missing / exception) sorted to the end; oldest workable first.



Live on your laptop



v1.1

UX-12	**LOW**	**Demo login helper only reacted when clicking the username text**	**FIXED**
Area	Login page		
Steps that caused it	1. Click on the role or password column of a demo login row.		
Expected	Row fills the form.		
Actual	Nothing happens.		
Fix / recommendation	Whole row clickable and keyboard accessible.		

UX-13	**LOW**	**Reprint reason: browser demanded 5 characters, server 3**	**FIXED**
Area	Reprint		
Steps that caused it	1. Reprint a slip with a 3-4 character reason via the API or without JavaScript.		
Expected	Same rule everywhere.		
Actual	Inconsistent.		
Fix / recommendation	Both require 5 characters.		

A11Y-01	LOW	**Form labels not connected to their fields**	FIXED
Area	Accessibility		
Steps that caused it	1. Use a screen reader or click a label text.		
Expected	Field is announced / focused.		
Actual	803 of 803 fields had no linked label.		
Fix / recommendation	Labels are linked automatically; 15 fields remain with placeholder text only.		

REC-03	LOW	**An approved (not yet paid) bill can still be rejected by another approver**	OPEN
Area	Reconciliation		
Steps that caused it	1. Approve a bill. 2. Another approver clicks Reject on it.		
Expected	Approved bills are changed only by an administrator with a reason.		
Actual	Rejected; links to invoices are removed.		
Fix / recommendation	Recommendation: allow reject only before approval, or require admin.		

INFO-01	INFO	**Print event is recorded when the print page opens, even if the printer dialog is cancelled**	BY DESIGN
Area	Slip printing		
Steps that caused it	1. Click Print Slip, then Cancel in the printer dialog.		
Expected	-		
Actual	Slip counts as printed; the next print is a reprint that needs a reason.		
Fix / recommendation	By design (prevents silent duplicate originals). Explained in the user guide.		

INFO-02	INFO	**Session cookie 'Secure' flag must be switched on with HTTPS**	CONFIG
Area	Deployment		
Steps that caused it	1. Deploy behind HTTPS.		
Expected	-		
Actual	Off by default (it would break plain-HTTP demos).		
Fix / recommendation	Set CTDMS_SESSION_COOKIE_SECURE=true in .env when served over HTTPS.		

INFO-03	**INFO**	**Login with Enter did not move to the next page in the desktop app's browser pane**	**NOT A BUG**
Area	Login		
Steps that caused it	1. Fill the login form programmatically and press Enter in the Claude browser pane.		
Expected	-		
Actual	Server accepted the login (HTTP 303) but the pane did not navigate.		
Fix / recommendation	Not an app bug: typing the password and pressing Enter works normally (re-tested).		

6. Open items and go-live recommendations

1. **Install v1.1** (steps in the user guide) and run the smoke test in section 1.3 of the guide.
2. **Rate-limit logins per IP** at the reverse proxy (Caddy/nginx) - today anyone can lock an account with 5 wrong passwords (SEC-10).
3. **Approved bills:** allow Reject only before approval or only for admins (REC-03).
4. **Production .env:** CTDMS_ENVIRONMENT=production, strong CTDMS_SECRET_KEY, HTTPS with CTDMS_SESSION_COOKIE_SECURE=true, FORWARDED_ALLOW_IPS set to the proxy network, no demo data.
5. **Phones:** if operators will use phones at the dock, consider a card layout for the pending list (UX-09 improved but the table still scrolls sideways).
6. **Backups:** keep the daily PostgreSQL backup job and test one restore before go-live.
7. **Printing rule:** tell operators that opening the print page counts as the original print (INFO-01).

7. Test statistics

Measure	v1.0	v1.1
Automated probe checks exposing a real problem (of 121)	23	0 (remaining flags are by design, configuration or test artefacts)
URL / form / upload patterns returning HTTP 500	20+	0
Largest upload accepted / time	28 MB, 184 s, 2.2 GB RAM	20 MB max, refused in < 1 s
Browser crawl: JS errors / slowest page	0 / 0.68 s	0 / 0.82 s
Form fields without a linked label	803 of 803	15 of 803
Automated tests	28 pass	71 pass (SQLite + PostgreSQL)